

Deep Learning para la Detección de Malware

Redes Neuronales Profundas Aplicadas a la Ciberseguridad

José Moreno, Itmar Castillo

Universidad Tecnológica de Panamá

Facultad de Ingeniería de Sistemas Computacionales

Mgter. Ana Villarreal — IA Aplicada a la Ciberseguridad

Resumen: A medida que el malware se vuelve más sofisticado y difícil de detectar, los métodos tradicionales basados en firmas resultan insuficientes para enfrentar el ritmo con el que aparecen nuevas amenazas unas 450,000 muestras diarias según AV-TEST (2024). En este trabajo se analiza cómo el Deep Learning, particularmente las redes CNN y RNN/LSTM, ofrece una alternativa más robusta al aprender directamente de los datos, sin depender de reglas escritas manualmente. Se cubren los tipos de datos que se pueden analizar, las arquitecturas más utilizadas, cómo se mide el rendimiento de estos modelos, casos reales como MalConv y el dataset EMBER, y los retos que aún quedan por resolver.

I. INTRODUCCIÓN

Hoy en día, la detección de malware es uno de los problemas más complicados en ciberseguridad. Los antivirus clásicos funcionan comparando archivos contra una base de datos de firmas conocidas, pero esta estrategia se queda corta frente a variantes polimórficas y metamórficas, que modifican su propio código para parecer diferentes en cada infección. Con tasas de detección que no superan el 72% para amenazas modernas, queda claro que hacen falta enfoques más inteligentes.

Ahí entra el Deep Learning. A diferencia de los métodos basados en reglas, estas redes aprenden representaciones directamente de los datos, lo que les permite generalizar a amenazas que nunca han visto. En este trabajo exploramos cómo se aplican arquitecturas CNN y LSTM a la detección de malware, qué tipo de datos procesan, cómo se evalúan y cuáles son los desafíos reales que enfrenta el campo.

II. ¿QUÉ ES DEEP LEARNING?

El Deep Learning es una rama del Machine Learning que trabaja con redes neuronales de muchas capas de ahí el término "profundo". Cada capa transforma la información de la anterior, construyendo representaciones cada vez más abstractas.

Lo interesante es que no hace falta definir manualmente qué características buscar; la red las descubre sola durante el entrenamiento.

Para entender su aplicación en ciberseguridad, conviene conocer las tres familias de arquitecturas más relevantes:

A. Redes Neuronales Convolucionales (CNN)

Las CNN fueron diseñadas originalmente para procesar imágenes, pero se adaptaron muy bien a datos secuenciales como los bytes de un ejecutable. Funcionan aplicando filtros deslizantes sobre la entrada para detectar patrones locales, por ejemplo, secuencias de bytes que aparecen repetidamente en una familia de malware. Su mayor ventaja es que no requieren que un experto extraiga características manualmente.

B. Redes Neuronales Recurrentes (RNN) y LSTM

Las RNN procesan secuencias paso a paso, manteniendo una especie de "memoria" del contexto anterior. El problema es que esa memoria se desvanece con secuencias largas el conocido problema del gradiente desvaneciente. Las LSTM solucionan esto con un sistema de compuertas que decide qué información conservar y cuál descartar.

Para analizar comportamientos de malware en el tiempo, resultan ideales. Las GRU son una alternativa más ligera con resultados comparables.

C. Modelos Ensemble e Híbridos

Cuando se combinan CNN y LSTM, se obtiene lo mejor de los dos mundos: la CNN analiza la estructura estática del archivo y la LSTM sigue el comportamiento en tiempo de ejecución. Los modelos ensemble que integran ambas fuentes de información son consistentemente los más precisos según la literatura.

III. ¿QUÉ ES EL MALWARE?

El término malware (malicious software) engloba cualquier programa diseñado para dañar, espiar o comprometer un sistema sin el consentimiento de su dueño. El volumen actual es difícil de dimensionar: según AV-TEST Institute, durante 2024 se registraron cerca de 450,000 muestras nuevas cada día. A ese ritmo, actualizar una base de firmas manualmente es simplemente inviable.

Las categorías más importantes son:

- Virus: se incrusta en archivos ejecutables y se propaga cuando el usuario los abre.
- Ransomware: cifra los datos de la víctima y exige un pago generalmente en criptomonedas para recuperarlos.
- Troyano: se presenta como software legítimo y, una vez dentro, abre puertas traseras al atacante.
- Spyware: recopila información sensible (credenciales, datos bancarios) sin que el usuario lo note.
- Rootkit: se oculta en las capas más bajas del sistema operativo para evitar ser detectado y eliminado.
- Botnet: red de máquinas infectadas que actúan de forma coordinada para lanzar ataques masivos como DDoS.

Identificar correctamente la familia del malware es fundamental en la respuesta a incidentes, porque cada tipo requiere un procedimiento de contención diferente.

IV. TIPOS DE DATOS ANALIZADOS

Una de las primeras decisiones al diseñar un sistema de detección basado en Deep Learning es qué información se le va a dar al modelo. Básicamente hay tres enfoques, y la elección depende del contexto de uso:

A. Análisis Estático

Consiste en examinar el archivo sin ejecutarlo. Se trabaja con los bytes crudos del ejecutable en formato PE (Portable Executable), las secciones de código (.text) y datos (.data), las DLL que el programa importa, el encabezado del archivo y las cadenas de texto embebidas. Es rápido y seguro, pero el malware que usa ofuscación o cifrado puede evadir este tipo de análisis.

B. Análisis Dinámico

Aquí el archivo se ejecuta en un entorno controlado (sandbox) y se observa lo que hace: qué llamadas al sistema realiza, cómo accede al registro de Windows, qué tráfico de red genera y si crea procesos hijos. Esto permite detectar malware que solo se activa bajo ciertas condiciones, aunque algunos ejemplares detectan el entorno virtual y modifican su comportamiento para pasar desapercibidos.

C. Análisis Híbrido

El híbrido combina lo mejor de ambos mundos: features estáticas junto con trazas de comportamiento dinámico, grafos de llamadas a funciones y modelos CNN+LSTM que procesan en paralelo. Según los resultados del dataset EMBER, este enfoque es el más robusto, aunque también el más costoso computacionalmente.

V. CNN Y RNN APLICADAS A LA DETECCIÓN DE MALWARE

A. CNN sobre Bytes Crudos: MalConv

MalConv, presentado por Raff et al. en 2018, marcó un antes y un después en el campo. Su propuesta fue simple pero efectiva: tomar los bytes crudos del ejecutable y pasarlos directamente a una CNN 1D, sin extraer ninguna característica manual. Cada byte se convierte en un vector de 8 dimensiones mediante una capa de embedding, y luego filtros convolucionales de hasta 500 posiciones detectan patrones relevantes.

El modelo procesa archivos de hasta 2 MB y tarda menos de 50 ms por archivo, lo que lo hace viable en producción. Con un 92.2% de accuracy sobre un millón de muestras, demostró que es posible detectar malware polimórfico el que cambia su firma en cada variante sin depender de esas firmas en absoluto.

B. LSTM sobre Secuencias de API Calls

Las LSTM abordan el problema desde otro ángulo: en vez de mirar el archivo, observan lo que hace cuando se ejecuta. Cada llamada al sistema (syscall) se trata como un token, y la secuencia completa es como una "frase" que describe el comportamiento del programa. Athiwaratkun y Stokes (2017) mostraron que LSTM y GRU superan a las RNN clásicas en esta tarea, gracias a su mejor manejo de dependencias a largo plazo.

Más allá de las syscalls, las LSTM bidireccionales también se usan para analizar tráfico de red en busca de conexiones a servidores de Comando y Control (C&C), y para procesar logs de eventos del sistema convertidos en embeddings.

VI. PRECISIÓN VS. FALSOS POSITIVOS

Evaluar un detector de malware con solo el accuracy puede ser engañoso. En la práctica, los archivos benignos superan en número a los maliciosos por miles, así que un modelo que diga "benigno" siempre

obtendría un accuracy alto sin detectar nada. La Tabla I muestra las métricas que realmente importan:

TABLA I. Métricas de evaluación en sistemas de detección de malware

Métrica	Fórmula	Valor	Significado
Accuracy	$(TP+TN)/Total$	98.3%	Clasif. correctos
Precision	$TP/(TP+FP)$	97.1%	Positivos correctos
Recall	$TP/(TP+FN)$	96.8%	Malware detectado
F1-Score	$2 \times (P \times R) / (P + R)$	96.9%	Balance P/R

El punto crítico es el umbral de decisión (threshold). Subirlo reduce los falsos positivos archivos legítimos bloqueados por error pero también deja escapar más malware. Bajarlo detecta más, pero genera bloqueos innecesarios. Para dimensionar el problema: con un FPR del 1% en un entorno de 10 millones de archivos diarios, se producirían 100,000 bloqueos falsos cada día.

Por eso, el F1-Score y el AUC-ROC son las métricas de referencia en la literatura. El umbral ideal varía según el contexto: en una empresa con infraestructura crítica conviene priorizar la detección aunque se bloqueen más cosas; para un usuario doméstico, minimizar las interrupciones puede ser más importante.

VII. COMPARATIVA DE MÉTODOS DE DETECCIÓN

La Tabla II compara los métodos más representativos, desde los enfoques clásicos hasta los modelos de DL:

TABLA II. Comparativa de métodos de detección de malware

Método	Datos	Accuracy	FPR
Firmas AV	Hash	72%	0.1%
Heurístico	Reglas	80%	5%

Método	Datos	Accuracy	FPR
ML Clásico (RF)	Features	89%	3%
CNN (MalConv)	Bytes raw	94%	1%
LSTM (API Calls)	Syscalls	93%	2%
CNN+LSTM Ensemble	Híbrido	98%	0.3%

El ensemble CNN+LSTM lidera en accuracy (98%) y FPR (0.3%), pero a precio de mayor latencia y necesidad de GPU. Para organizaciones con infraestructura dedicada, es la opción más sólida. MalConv, en cambio, ofrece un punto medio muy razonable: 94% de accuracy con velocidad comparable a los antivirus tradicionales.

VIII. CASO REAL: EMBER Y MALCONV

EMBER (Endgame Malware BEnchmark for Research), publicado por Anderson y Roth en 2018, es hoy el benchmark más utilizado para comparar clasificadores de malware en archivos PE de Windows. Incluye un millón de muestras 800,000 para entrenamiento y 200,000 para prueba con features derivadas del encabezado, secciones, importaciones de DLL y strings del ejecutable.

El modelo base de EMBER usa LightGBM sobre esas features y alcanza un AUC-ROC de 98.2%. Pero Microsoft Research fue un paso más allá: al combinar los bytes crudos del ejecutable procesado por CNN con las features tabulares de EMBER, la tasa de detección subió al 99.1% con un FPR por debajo del 0.1%, estableciendo el estado del arte en la tarea.

IX. RETOS ACTUALES

A pesar de los resultados prometedores, hay varios obstáculos que frenan la adopción masiva de estos sistemas en producción:

A. Ataques Adversariales

El más preocupante es quizás el de los ataques adversariales: modificar el binario

malicioso, por ejemplo, añadiendo bytes inertes al final del archivo de forma que el clasificador lo marque como benigno, sin alterar su funcionalidad dañina. Es una carrera armamentista constante: el atacante adapta su malware, el modelo se re-entrena, y así sucesivamente.

B. Dataset Poisoning

Si un atacante logra introducir muestras maliciosas etiquetadas como benignas en el conjunto de entrenamiento, puede degradar el modelo silenciosamente. Detectar ese envenenamiento a tiempo sigue siendo un problema abierto.

C. Concept Drift

Las familias de malware no se quedan estáticas. Un modelo entrenado hace seis meses puede volverse ineficaz frente a variantes que explotan vectores de ataque completamente nuevos. Los sistemas de producción necesitan pipelines de re-entrenamiento continuo con muestras recientes.

D. Costo Computacional e Interpretabilidad

Los modelos más precisos requieren GPU para funcionar en tiempo real, lo que complica su despliegue en endpoints con recursos limitados, como dispositivos IoT o móviles. A esto se suma que son esencialmente cajas negras: difíciles de auditar y de justificar ante requisitos regulatorios como GDPR. Las técnicas de XAI (Explainable AI), como SHAP y LIME, intentan remediar esto, pero siguen siendo un área en desarrollo.

X. CONCLUSIONES

El Deep Learning ha demostrado ser claramente superior a los métodos tradicionales para detectar malware. Pasar del 72% de accuracy de los antivirus basados en firmas al 94–98% de los modelos CNN y LSTM es un salto que tiene un impacto real en la seguridad de cualquier organización.

El enfoque híbrido CNN+LSTM, que combina análisis estático y dinámico, ofrece la mejor relación precisión/falsos positivos, aunque no siempre es viable por su costo computacional. En esos casos, MalConv representa una alternativa práctica y bien estudiada.

Dicho esto, la tecnología por sí sola no es suficiente. Los ataques adversariales, el concept drift y la falta de interpretabilidad siguen siendo problemas reales que requieren supervisión humana. El futuro pasa por modelos más robustos como SecurityBERT, basado en transformers y por una integración más estrecha entre herramientas automatizadas y analistas de seguridad.

Finalmente, vale la pena subrayar que elegir bien las métricas de evaluación F1-Score y AUC-ROC en lugar de accuracy simple es tan importante como el modelo en sí, especialmente en escenarios donde la mayoría de los archivos son benignos.

REFERENCIAS

- E. Raff et al., "Malware Detection by Eating a Whole EXE," AAAI Workshop on AI for Cybersecurity, 2018.
- H. S. Anderson y P. Roth, "EMBER: An Open Dataset for Training Static PE Malware Machine Learning Models," arXiv:1804.04637, 2018.
- M. Sewak, S. K. Sahay, y H. Rathore, "An Overview of Deep Learning Architecture," Int. Journal of Next-Generation Computing, 2018.
- Y. Ye et al., "A Survey on Malware Detection Using Data Mining Techniques," ACM Comput. Surv., vol. 50, no. 3, 2017.
- I. Goodfellow, Y. Bengio, y A. Courville, Deep Learning. MIT Press, 2016. [En línea]. Disponible: <http://www.deeplearningbook.org>
- Microsoft Research, "Windows Malware Dataset with PE API Calls," 2022. [En línea]. Disponible: <https://github.com/microsoft/malware-detection>
- B. Athiwaratkun y J. W. Stokes, "Malware Classification with LSTM and GRU," Proc. IEEE ICASSP, 2017, pp. 2482–2486.
- AV-TEST Institute, "The AV-TEST Security Report 2023/2024," AV-TEST GmbH, Magdeburg, Alemania, 2024.